Prácticas de seguridad de MongoDB 8.0

Laboratorio 1 — Un lector puede consultar, pero no escribir

Objetivo: comprobar tres situaciones reales: lectura anónima rechazada; lectura autorizada al usuario `lectorlab`; intento de inserción rechazado para el mismo usuario.

Paso 1 — Saber qué servidor utilizaremos

Este laboratorio usa `mongo-seguridad`, **no** `mongo-indices`. Se trata de dos instancias de MongoDB diferentes dentro del mismo proyecto. La base de datos se llama `curso_seguridad` y su colección de práctica, `secretos`.

Abre PowerShell o Terminal en la raíz del repositorio (debe existir `compose.yaml`). Si no has preparado `.env`, copia `.env.example` y cambia las contraseñas de demostración `MONGO_ADMIN_PASSWORD`, `LAB_READER_PASSWORD` y `LAB_WRITER_PASSWORD`. No uses contraseñas personales.

PowerShell:

```
Copy-Item .env.example .env
```

Bash:

```
cp .env.example .env
```

Paso 2 — Arrancar la instancia protegida

En PowerShell o Bash, no dentro de `mongosh`:

```
docker compose up -d --wait mongo-seguridad
docker compose ps
```

Comprueba que `mongo-seguridad` aparece en ejecución. Si cambias la contraseña en `.env` después de haber creado la instancia con otros datos persistentes, eso no actualiza automáticamente al usuario existente. Consulta con el formador antes de eliminar volúmenes.

Paso 3 — Entrar como administrador

```
docker compose exec mongo-seguridad mongosh --username adminlab --authenticationDatabase admin
--password
```

Introduce la clave de `MONGO_ADMIN_PASSWORD` cuando se solicite. Ahora estás dentro de `mongosh`. Confirma la conexión:

```
db.adminCommand({ping:1})
```

Debe aparecer `ok:1`. Esto demuestra que el servidor responde, **no** que todas las cuentas ya existan.

Paso 4 — Preparar un documento ficticio

Todavía dentro de `mongosh`:

```
const curso = db.getSiblingDB("curso_seguridad")
curso.secretos.insertOne({
  _id: "demo-1",
  texto: "registro autorizado",
  clasificacion: "docente"
})
```

`getSiblingDB` selecciona otra base de datos sin cerrar tu conexión. `insertOne` crea un documento. Si aparece error de identificador duplicado, quizás realizaste antes la práctica: comprueba `curso.secretos.findOne({_id:"demo-1"})` y evita repetir la inserción.

Paso 5 — Crear los usuarios con permisos diferentes

Con la conexión administrativa:

```
curso.createUser({
  user:"lectorlab",
  pwd:process.env.LAB_READER_PASSWORD,
  roles:[{role:"read",db:"curso_seguridad"}]
})
```

El ejemplo obtiene la contraseña reservada al lector desde las variables del contenedor que Compose carga de `.env`, y evita escribir la clave en la guía. Después:

```
curso.createUser({
  user:"escritorlab",
  pwd:process.env.LAB_WRITER_PASSWORD,
  roles:[{role:"readWrite",db:"curso_seguridad"}]
})
```

Importante: si los usuarios ya existen, MongoDB lo indicará. No los borres automáticamente; consulta al formador o comprueba su existencia con `curso.getUser("lectorlab")`.

`read` permite consultar documentos; `readWrite` permite además modificarlos en esa base de datos.

Paso 6 — Intentar leer sin credenciales

Escribe `exit` para abandonar `mongosh`. De nuevo en PowerShell o Bash:

```
docker compose exec mongo-seguridad mongosh
```

Dentro del nuevo `mongosh` anónimo:

```
db.getSiblingDB("curso_seguridad").secretos.findOne({_id:"demo-1"})
```

Resultado esperado: error de autorización. El hecho de poder establecer una conexión no equivale a tener permiso para leer. Anota el mensaje y explica qué control ha actuado. Después escribe `exit`.

Paso 7 — Leer como usuario autorizado

Desde PowerShell o Bash:

```
docker compose exec mongo-seguridad mongosh --username lectorlab --authenticationDatabase
curso_seguridad --password
```

Escribe la contraseña del lector. Dentro de `mongosh`:

```
db.getSiblingDB("curso_seguridad").secretos.findOne({_id:"demo-1"})
```

Resultado esperado: aparece el documento con el texto `registro autorizado`. Esta vez se han cumplido dos condiciones: la identidad del lector es válida y su rol permite leer.

Paso 8 — Provocar la denegación correcta

Sin salir de la sesión del lector, ejecuta:

```
db.getSiblingDB("curso_seguridad").secretos.insertOne({
  _id:"prohibido",
  texto:"el lector no deberia poder crear esto"
})
```

Resultado esperado: error `Unauthorized` o equivalente. Esta es precisamente la protección que queríamos demostrar.

Si la inserción funciona, has encontrado un problema en la preparación: comprueba qué usuario está conectado y los roles que le fueron asignados. No continúes fingiendo que el ejercicio ha pasado.

Paso 9 — Contrastar con el usuario escritor

Sal con `exit`. Conecta con la cuenta que sí debe escribir:

```
docker compose exec mongo-seguridad mongosh --username escritorlab --authenticationDatabase
curso_seguridad --password
```

Dentro de `mongosh`:

```
db.getSiblingDB("curso_seguridad").secretos.insertOne({
  _id:"permitido",
  texto:"el escritor si puede insertar"
})
```

Resultado esperado: inserción confirmada.

Paso 10 — Registrar la evidencia y cerrar

Prueba	Resultado correcto	Resultado observado
Anónimo intenta leer	Denegado	____
Lector intenta leer	Permitido	____
Lector intenta insertar	Denegado	____
Escritor intenta insertar	Permitido	____

Explica por escrito por qué **no** sería correcto resolver la tercera prueba dando al lector permisos administrativos.

Sal de `mongosh` y detén el servicio desde la terminal:

```
docker compose stop mongo-seguridad
```

Este comando detiene el contenedor y conserva sus datos. La nueva configuración del proyecto utiliza **volúmenes Docker con nombre** para almacenar los datos de cada instancia; `docker compose down` elimina contenedores, pero no esos volúmenes con nombre. **`docker compose down --volumes` sí los elimina** y perderás los datos, usuarios y documentos de práctica. No lo ejecutes salvo que quieras reinicializar conscientemente el laboratorio.

Siguiente práctica: cifrado TLS y certificados X.509, comenzando por la diferencia entre canal seguro e identidad del cliente.

Laboratorio 2 — Distinguir errores de conexión, autenticación y autorización

Objetivo

Aprenderás a diagnosticar tres fallos que a veces producen mensajes parecidos, pero que tienen soluciones completamente diferentes. Esta práctica no consiste en «hacer que todo funcione»: algunas operaciones están diseñadas para ser rechazadas. Debes explicar **cuál es la condición que falla**.

Continuamos con los usuarios y datos preparados en la primera práctica. Si todavía no has creado `lectorlab` y `escritorlab`, realiza el laboratorio 1 antes de seguir.

Paso 1. Distinguir los tres planos

Imagina que te presentas ante una puerta:

- Si el edificio está cerrado y no existe acceso físico, no puedes siquiera contactar con el responsable de recepción.
- Si consigues llegar pero te identificas con una credencial incorrecta, **falla la autenticación**.
- Si te identificas correctamente pero intentas entrar en un área restringida, **falla la autorización**.

El laboratorio reproduce las tres situaciones utilizando un servicio, unas credenciales y una operación.

Paso 2. Comprobar la disponibilidad del servicio

Desde PowerShell o Bash en la raíz del proyecto:

```
docker compose ps
```

Comprueba que `mongo-seguridad` está en marcha. Si está detenido, arráncalo:

```
docker compose up -d --wait mongo-seguridad
```

¿Aparece como `healthy`? Si no, todavía no intentes interpretar errores de contraseñas. Un servidor que no arrancó no puede validar credenciales.

Paso 3. Provocar una denegación por no autenticarse

En una terminal abre `mongosh` sin nombre ni contraseña:

```
docker compose exec mongo-seguridad mongosh
```

Dentro del shell:

```
db.getSiblingDB("curso_seguridad").secretos.findOne({_id:"demo-1"})
```

Debe obtenerse una denegación de acceso. El error significa que el servidor está activo y ha recibido la solicitud, pero no ha autorizado leer esa colección.

No concluyas que el puerto está bloqueado: de hecho, llegaste al servidor. Sal mediante `exit`.

Paso 4. Probar una contraseña equivocada

Conecta desde la terminal como `lectorlab`, pero introduce voluntariamente una contraseña diferente de la que preparaste:

```
docker compose exec mongo-seguridad mongosh --username lectorlab --authenticationDatabase
curso_seguridad --password
```

Aquí se espera un fallo de **autenticación**. La cuenta no ha demostrado conocer el secreto correcto, por lo que no puede ser reconocida como `lectorlab`.

Registra el texto del error o la información esencial, **sin escribir contraseñas en tu informe**. Si la consola muestra de nuevo el prompt de autenticación, no repitas intentos indefinidamente.

Paso 5. Probar la base de autenticación incorrecta

Ahora prueba a iniciar sesión con las credenciales correctas del lector pero indicando `admin`:

```
docker compose exec mongo-seguridad mongosh --username lectorlab --authenticationDatabase admin
--password
```

En este laboratorio la cuenta `lectorlab` se creó asociada a `curso_seguridad`, no a `admin`. Por tanto, esperamos un fallo de autenticación en esa combinación.

Pregunta: **¿qué cambió respecto a un inicio de sesión correcto?** No fue necesariamente el usuario ni la contraseña: cambió el lugar donde el servidor busca esa identidad.

Paso 6. Conectar correctamente y probar lectura

```
docker compose exec mongo-seguridad mongosh --username lectorlab --authenticationDatabase
curso_seguridad --password
```

Introduce ahora la contraseña verdadera del lector. Dentro de `mongosh` ejecuta:

```
db.getSiblingDB("curso_seguridad").secretos.findOne({_id:"demo-1"})
```

Debe aparecer el documento de prueba. Esta comprobación es imprescindible: sin una prueba de lectura permitida no sabemos si la cuenta está preparada de forma correcta.

Paso 7. Probar dos escrituras diferentes

Todavía conectado como lector, intenta modificar el documento:

```
db.getSiblingDB("curso_seguridad").secretos.updateOne(
  {_id:"demo-1"},
  {$set:{texto:"modificado sin permiso"}}
)
```

Resultado esperado: denegación. El filtro identifica un documento existente, pero el rol `read` no permite actualizarlo.

Después intenta eliminarlo:

```
db.getSiblingDB("curso_seguridad").secretos.deleteOne({_id:"demo-1"})
```

Resultado esperado: denegación otra vez. El mismo rol impide la eliminación.

Observa la diferencia respecto al paso 4. **Aquí no falla la autenticación:** has podido leer con esta misma sesión. Lo que falla es que intentas una acción no autorizada.

Paso 8. Comprobar que nada se modificó

```
db.getSiblingDB("curso_seguridad").secretos.findOne({_id:"demo-1"})
```

El campo `texto` debería conservar su valor original `registro autorizado`. Así comprobamos que las denegaciones protegieron los datos, no simplemente que apareció un mensaje de error.

Si el documento ha cambiado, es posible que estuvieras conectado con una identidad más privilegiada. Detente, registra el problema y consulta qué usuario está realmente autenticado antes de repetir la prueba.

Paso 9. Completar un diagnóstico por causas

Experimento	El servidor respondió	Credenciales válidas	Permiso para la operación
Lectura anónima	Sí	No	No
Contraseña equivocada	Sí	No	No se llega a comprobar
Base de autenticación incorrecta	Sí	No	No se llega a comprobar
Lectura como lector	Sí	Sí	Sí
Actualizar como lector	Sí	Sí	No
Borrar como lector	Sí	Sí	No

Esta tabla no es un ejercicio de memoria: explica cada fila con el comando que ejecutaste y el resultado observado.

Paso 10. Resolver errores de preparación

Si la contraseña correcta no funciona, verifica:

1. que el usuario fue creado en el laboratorio 1;
2. que lo estás buscando en `curso_seguridad`;
3. que `.env` contiene la contraseña que utilizaste originalmente;
4. que no reutilizaste una instancia de MongoDB inicializada con otra configuración.

No borres volúmenes para «arreglar la autenticación» sin consultar primero al formador: perderías cuentas y documentos de la práctica.

Laboratorio 3 — TLS: probar un canal seguro, no solo una contraseña

Qué vamos a conseguir

La instancia `mongo-tls` exige TLS. Vamos a demostrar dos resultados complementarios:

1. una conexión **sin TLS** es rechazada;
2. una conexión TLS **que valida la CA local** puede hablar con el servidor.

Ninguna de esas dos pruebas significa por sí sola que el cliente tenga permisos para consultar las colecciones protegidas. El objetivo es distinguir **protección del canal** de **autorización de datos**.

Paso 1. Requisitos concretos

Este laboratorio requiere:

- Docker Desktop o Docker Engine con Compose;
- Bash y OpenSSL, por ejemplo mediante Git Bash o WSL en Windows;
- la carpeta del proyecto con `compose.yaml` y el script `scripts/generar-certificados.sh`;
- un archivo `.env` con una contraseña de demostración para `MONGO_ADMIN_PASSWORD`.

Nunca utilices certificados de producción ni contraseñas personales. El procedimiento genera una autoridad de certificación de laboratorio y material de clave con permisos simplificados para contenedores desechables.

Paso 2. Preparar los certificados locales

Abre **Bash** en la carpeta principal del repositorio:

```
bash scripts/generar-certificados.sh
```

Debes observar una confirmación de verificación criptográfica. En la carpeta `certs` aparecerán, entre otros, `ca.crt`, `server.pem` y `client.pem`.

Qué representa cada archivo:

- `ca.crt`: certificado de la CA con el que se verifica la cadena de confianza.
- `server.pem`: certificado de servidor y material asociado necesario para presentarlo.
- `client.pem`: material de certificado del alumno para el laboratorio X.509.

No compartas `server.pem` ni `client.pem`: en este laboratorio incluyen claves privadas. La carpeta `certs` está excluida del control de versiones.

Paso 3. Arrancar el servidor que exige TLS

```
docker compose up -d --wait mongo-tls
docker compose ps
```

Debe aparecer `mongo-tls` en ejecución. El puerto del host es `127.0.0.1:27019`, pero las órdenes del laboratorio se ejecutan dentro del contenedor y usan `localhost`, donde MongoDB escucha en su puerto interno.

Si no arranca, consulta:

```
docker compose logs --tail=100 mongo-tls
```

Errores relacionados con certificado, clave o archivo inexistente requieren volver a comprobar el paso 2.

Paso 4. Intentar conectar SIN TLS

Desde PowerShell o Bash:

```
docker compose exec -T mongo-tls mongosh --quiet --host localhost --eval
'db.adminCommand({ping:1})'
```

Resultado esperado: la conexión falla. No lo registres como fracaso del ejercicio: el servidor está configurado para exigir un canal cifrado.

La pregunta que debes responder es: ¿qué intentaste hacer y qué propiedad de seguridad impidió que se aceptara?

Paso 5. Repetir la conexión con TLS y CA

```
docker compose exec -T mongo-tls mongosh --quiet --host localhost --tls --tlsCAFile /certs/
ca.crt --eval 'printjson(db.adminCommand({ping:1}))'
```

Ahora introduces dos elementos:

- `--tls`: pide un canal TLS.
- `--tlsCAFile /certs/ca.crt`: proporciona la CA de confianza que permitirá verificar al servidor.

Resultado esperado: documento con `ok:1`.

Muy importante: `ping` confirma que el servidor es accesible usando ese canal; no demuestra todavía que esa conexión pueda leer una colección protegida.

Paso 6. Explicar qué cambió y qué no cambió

Completa:

Prueba	TLS utilizado	Resultado esperado
`ping` sin `--tls`	No	Conexión rechazada
`ping` con `--tls` y CA	Sí	Respuesta `ok:1`

El servidor no empezó a permitir escritura al activar TLS. Lo que cambió fue que el cliente negoció un canal protegido. Las decisiones sobre identidad y roles se estudiarán en el laboratorio siguiente.

Paso 7. Ver el certificado sin exponer su clave

En Bash, desde la raíz del proyecto:

```
openssl x509 -in certs/server.crt -noout -subject -issuer -dates
```

Observa:

- `subject`: la identidad para la que se emitió el certificado;
- `issuer`: su emisor;
- `notBefore` y `notAfter`: su intervalo de validez.

No pegues claves privadas ni contraseñas en el informe. Los metadatos del certificado bastan para esta actividad.

Paso 8. Preguntas antes de continuar

1. Si `ping` funciona con TLS, ¿significa que puedes leer todos los datos?
2. ¿Qué función cumple la CA?
3. ¿Cuál de los archivos debemos proteger especialmente porque incorpora material de clave privada?
4. ¿Por qué es incorrecto solucionar un error de confianza desactivando indiscriminadamente la validación de certificados?

Laboratorio 4 — X.509 y privilegios: autenticarse con un certificado de cliente

4.1. La pregunta que cambia

En el laboratorio anterior el cliente verificó al servidor. Ahora queremos que **el servidor identifique al cliente** mediante un certificado X.509.

El mecanismo de MongoDB que vamos a utilizar se llama `MONGODB-X509`. La identidad vive en la base especial `$external`, pero sus privilegios se asignan igualmente mediante roles.

Vamos a demostrar:

- el cliente puede autenticarse mediante su certificado;
- con un rol de lectura puede consultar un documento;
- la misma identidad no puede insertar.

Paso 1. Trabajar sobre un entorno de laboratorio nuevo

El script de comprobación completo crea cuentas de ejemplo, incluida la cuenta administrativa inicial de la instancia TLS. Se diseñó para ejecutarse sobre contenedores **desechables recién creados**. Si ya has creado manualmente `admincert` o las cuentas de ejemplo, volver a ejecutar todas las operaciones de inicialización puede fallar por usuarios existentes.

Antes de repetir el flujo completo, pregunta al formador si la instancia `mongo-tls` contiene algo que deba conservarse. No reinicies ni elimines datos reales.

La validación automatizada de GitHub Actions utiliza un entorno limpio en cada ejecución precisamente para evitar ambigüedades de este tipo.

Paso 2. Preparar un shell Bash y las variables

Desde la raíz del repositorio, comprueba que has generado certificados con el script anterior. Utiliza una copia local de `.env` creada y revisada por ti; no ejecutes ni importes archivos de configuración de origen desconocido.

Para pasar las contraseñas de demostración al entorno de **ese Bash**, puedes usar:

```
set -a
source ./.env
set +a
```

Esto carga valores definidos en `.env`. **Solo hazlo con un archivo de tu propia carpeta que hayas inspeccionado**, porque `source` ejecuta sintaxis de shell. Si utilizas una configuración de claves más avanzada, exporta las variables según las instrucciones de tu plataforma en lugar de ejecutar archivos ajenos.

Las tres variables que necesita el script son `MONGO_ADMIN_PASSWORD`, `LAB_READER_PASSWORD` y `LAB_WRITER_PASSWORD`.

Paso 3. Ejecutar el flujo de validación completo

Con los servicios de seguridad preparados y el entorno limpio:

```
docker compose up -d --wait mongo-seguridad mongo-tls
bash scripts/probar-seguridad.sh
```

El script lleva a cabo varias verificaciones, no solamente X.509. Entre otras cosas:

1. Prepara las cuentas SCRAM de `mongo-seguridad`.
2. Comprueba rechazos esperados por ausencia o error de credenciales.
3. Comprueba permisos de lectura y escritura.
4. Confirma que `mongo-tls` exige TLS.
5. Registra el usuario de certificado y prueba su acceso.
6. Exige una **denegación** cuando el usuario X.509 de solo lectura intenta insertar.

No des por aprobado el ejercicio si el script termina antes del mensaje final de éxito. Si aparece error, identifica en qué paso se produjo. La prueba está automatizada para poder reproducirla de la misma forma que los controles ejecutados en GitHub.

Paso 4. Entender la identidad del certificado

Puedes inspeccionar el sujeto del certificado del alumno sin mostrar su clave privada:

```
openssl x509 -in certs/client.crt -noout -subject -nameopt RFC2253
```

Verás un DN que representa una identidad como `CN=alumno-x509,OU=Alumnos,O=MongoDBFormacion`.

En el script `lab/tls-usuario-x509.js`, la identidad se registra en `$external` con un rol `read` sobre `curso_cert`. No es necesario copiar contraseñas dentro de ese usuario: la autenticación se basa en su certificado y clave, con la configuración correspondiente del servidor.

Paso 5. Reconocer las opciones del cliente

El flujo de validación utiliza una combinación conceptualmente equivalente a:

```
mongosh --tls --tlsCAFile /certs/ca.crt --tlsCertificateKeyFile /certs/client.pem --
authenticationMechanism MONGODB-X509 --authenticationDatabase '$external'
```

Este fragmento muestra **las opciones esenciales**: en una conexión real también debes indicar el servidor adecuado y la ruta de los archivos, que aquí son rutas internas del contenedor. La ejecución completa, con argumentos correctos, está incluida en `scripts/probar-seguridad.sh`.

- `--tls` establece el canal protegido.
- `--tlsCAFile` valida la CA del servidor.
- `--tlsCertificateKeyFile` presenta las credenciales del cliente.
- `--authenticationMechanism MONGODB-X509` indica el tipo de autenticación.
- `--authenticationDatabase '$external'` indica el almacén especial de identidades externas.

Observa las comillas alrededor de `'$external'`: impiden que Bash interprete ese símbolo como una variable de shell.

Paso 6. Distinguir las dos pruebas finales

El script intenta leer un documento protegido en `curso_cert.pruebas` con el certificado del alumno. Eso debe funcionar si la identidad y su rol de lectura están configurados.

Después intenta insertar otro documento. Eso debe fallar porque la cuenta únicamente posee lectura.

Conclusión correcta: X.509 logró demostrar la identidad; RBAC limitó sus acciones. No hay contradicción entre «usuario autenticado» y «escritura rechazada».

Paso 7. Resolver fallos con criterio

- **El servidor no arranca:** revisa certificado de servidor, rutas y permisos de archivos.
- **Falla la conexión TLS:** comprueba la CA, el certificado y el nombre de servidor.
- **TLS funciona, pero X.509 no autentica:** inspecciona el DN, la cuenta registrada en `$external` y el mecanismo indicado.
- **X.509 autentica, pero no lee:** revisa el rol concedido y la base de datos sobre la que aplica.
- **El lector consigue insertar:** sería una anomalía de autorización: examina sus roles y comprueba que no estás conectado como administrador.

No resuelvas todos estos fallos dando permisos `root`. Cada uno pertenece a una capa diferente.

Paso 8. Síntesis escrita

Redacta cuatro frases:

1. Qué demuestra el certificado de servidor.
2. Qué demuestra el certificado de cliente.
3. Qué permite un rol `read`.
4. Qué resultado negativo debe obtener el usuario de certificado si intenta insertar.

Ampliación conceptual: distingue la función de LDAP, el cifrado de datos en reposo y las copias de seguridad. No tenemos un entorno Enterprise dentro de este laboratorio; por tanto, esos mecanismos no se presentarán como probados.

Laboratorio 5 — Crear un rol propio: una cuenta solo puede leer una colección

La necesidad real

Hasta ahora hemos utilizado el rol predefinido `read`. Con él, `lectorlab` puede consultar datos de su base según los privilegios que otorga ese rol. Pero imaginemos un requisito más restrictivo:

> «El equipo de control solo puede consultar la colección `secretos`, no cualquier otra colección de la base `curso_seguridad`».

Esta diferencia es importante. El permiso de lectura sobre **toda una base** no es idéntico al permiso sobre **una colección concreta**.

Vamos a crear un rol personalizado de lectura para una sola colección y una cuenta distinta que lo utilice. No modificaremos los roles de `lectorlab` o `escritorlab` para que las prácticas anteriores sigan siendo repetibles.

Paso 1. Preparar el entorno protegido

Abre PowerShell o Bash en la raíz del proyecto:

```
docker compose up -d --wait mongo-seguridad
```

Accede como administrador:

```
docker compose exec mongo-seguridad mongosh --username adminlab --authenticationDatabase admin
--password
```

Introduce la contraseña administrativa de tu archivo local `.env`. Dentro de `mongosh` confirma que estás conectado:

```
db.adminCommand({ping:1})
```

La respuesta `ok:1` confirma comunicación con el servidor; no sustituye las pruebas de permisos posteriores.

Paso 2. Preparar dos colecciones claramente distintas

Dentro de `mongosh`:

```
const s = db.getSiblingDB("curso_seguridad");
s.secretos.findOne({_id:"demo-1"});
s.publicaciones_demo.updateOne(
  {_id:"publica-1"},
  {$set:{titulo:"Información de ensayo"}},
  {upsert:true}
);
```

El `upsert` insertará el documento si todavía no existe o lo actualizará si existe. Estamos utilizando únicamente datos ficticios de laboratorio.

Tenemos dos colecciones:

- `secretos`: la que permitiremos consultar.
- `publicaciones_demo`: la que el nuevo usuario **no debería** poder leer.

Paso 3. Definir un rol personalizado

```
s.createRole({
  role:"soloSecretosClase",
  privileges:[
    {
      resource:{db:"curso_seguridad",collection:"secretos"},
      actions:["find"]
    }
  ],
  roles:[]
});
```

Descompongámoslo:

- `role` asigna un nombre a la definición.
- `privileges` contiene permisos explícitos.
- `resource` indica la base y colección permitidas.
- `actions:["find"]` limita la acción a consulta de documentos.
- `roles:[]` no incorpora otros roles heredados.

No hemos concedido `insert`, `update`, `remove` ni privilegios sobre `publicaciones_demo`.

Si el comando informa de que el rol ya existe, seguramente repetiste el laboratorio. Pide información con `s.getRole("soloSecretosClase",{showPrivileges:true})` en lugar de borrarlo automáticamente.

Paso 4. Crear la cuenta de prueba

```
s.createUser({
  user:"auditorclase",
  pwd:process.env.LAB_READER_PASSWORD,
  roles:[{role:"soloSecretosClase",db:"curso_seguridad"}]
});
```

Para simplificar un entorno docente, esta identidad de demostración reutiliza el **valor ficticio local** `LAB_READER_PASSWORD` del contenedor. En producción se utilizarían credenciales independientes; nunca compartas una contraseña entre cuentas reales.

Si la cuenta ya existe, examina `s.getUser("auditorclase")`. No confundas un error por duplicidad de nombre con un error de permisos.

Paso 5. Probar una lectura permitida

Sal de `mongosh` con `exit`. Desde la terminal:

```
docker compose exec mongo-seguridad mongosh --username auditorclase --authenticationDatabase
curso_seguridad --password
```

Introduce la contraseña que asignaste. Dentro del shell:

```
db.getSiblingDB("curso_seguridad").secretos.findOne({_id:"demo-1"})
```

Resultado esperado: aparece el documento ficticio, porque el rol contiene la acción `find` sobre esta colección.

Paso 6. Probar una lectura que debe rechazarse

Sin cambiar de cuenta:

```
db.getSiblingDB("curso_seguridad").publicaciones_demo.findOne({_id:"publica-1"})
```

Resultado esperado: error de autorización. Hemos demostrado un permiso más preciso que el rol `read` aplicado a toda la base.

Si puedes consultar ambas colecciones, revisa qué roles reales tiene `auditorclase`. No declares el ejercicio aprobado hasta explicar por qué una cuenta con un supuesto rol limitado puede acceder a recursos adicionales.

Paso 7. Probar una inserción prohibida

```
db.getSiblingDB("curso_seguridad").secretos.insertOne({
  _id:"no-autorizado-clase",
  texto:"prueba prohibida"
})
```

También debe rechazarse. Aunque el usuario pueda leer `secretos`, no tiene acción `insert`.

Paso 8. Documentar la matriz de permisos

Cuenta	Leer secretos	Leer publicaciones_demo	Escribir secretos
`auditorclase` con rol nuevo	Sí	No	No
`lectorlab` con rol read	Sí	Sí	No
`escritorlab` con rol readWrite	Sí	Sí	Sí

La segunda y tercera fila describen lo que esperamos de los roles anteriores en esta base. Si tu instalación no tiene las cuentas preparadas, realiza primero el laboratorio 1.

Paso 9. Preguntas de reflexión

1. ¿Qué diferencia hay entre asignar un rol `read` sobre la base completa y `find` sobre una única colección?
2. ¿Por qué el nombre del rol `soloSecretosClase` no basta para demostrar lo que permite?
3. ¿Qué riesgo aparecería si le otorgaras el rol `root` «para asegurarte de que funcione»?

4. ¿Qué prueba negativa necesitas para confirmar que el rol es realmente restrictivo?

Conclusión: el mínimo privilegio requiere concretar recursos y acciones, no simplemente crear usuarios con nombres que suenen seguros.

Laboratorio 6 — Cambiar permisos con control y comprobar que las sesiones reflejan la política

Propósito

A veces un permiso debe ampliarse temporalmente, por ejemplo para que un empleado pueda corregir datos durante una ventana autorizada. También debe poder retirarse después. Vamos a razonar sobre el ciclo de vida de un privilegio sin modificar la cuenta principal `lectorlab` del curso.

Aviso: esta actividad altera roles y usuarios de laboratorio. No la ejecutes en un sistema real ni sobre una cuenta ajena.

Paso 1. Crear una identidad temporal

En una sesión administrativa como en el laboratorio anterior:

```
const s = db.getSiblingDB("curso_seguridad");
s.createUser({
  user:"temporalclase",
  pwd:process.env.LAB_READER_PASSWORD,
  roles:[{role:"read",db:"curso_seguridad"}]
});
```

Su estado inicial es claro: puede consultar, pero no escribir. La contraseña de esta cuenta de demostración procede de `LAB_READER_PASSWORD`; no utilices ese patrón para cuentas reales.

Paso 2. Verificar antes de cambiar nada

Cierra la sesión administrativa y conecta como `temporalclase`:

```
docker compose exec mongo-seguridad mongosh --username temporalclase --authenticationDatabase
curso_seguridad --password
```

Comprueba lectura permitida:

```
db.getSiblingDB("curso_seguridad").secretos.findOne({_id:"demo-1"})
```

Después intenta:

```
db.getSiblingDB("curso_seguridad").secretos.insertOne({_id:"temporal-1"})
```

Resultado esperado: denegación. Si este caso no se cumple, carecerá de sentido estudiar el cambio de permisos.

Paso 3. Autorizar temporalmente escritura

Sal de la sesión del usuario y vuelve a entrar como administrador. Dentro del shell administrativo:

```
const s = db.getSiblingDB("curso_seguridad");
s.grantRolesToUser(
  "temporalclase",
  [{role:"readWrite",db:"curso_seguridad"}]
)
```

Esta operación añade el rol `readWrite`. No es lo mismo que sustituir por completo la cuenta ni borrar el rol `read` anterior. Si vas a cambiar privilegios en una aplicación real, debes estudiar además cuándo las sesiones existentes perciben los cambios y cómo se gestionan sus credenciales.

Paso 4. Verificar el cambio con una conexión nueva

Cierra la conexión administrativa y abre una **nueva sesión** como `temporalclase` para evitar dudas de estado de autenticación:

```
docker compose exec mongo-seguridad mongosh --username temporalclase --authenticationDatabase
curso_seguridad --password
```

Ahora intenta insertar `{_id:"temporal-1",texto:"autorizado durante la ventana"}`.

Resultado esperado: operación permitida si el rol se asignó correctamente. Si existe ya un documento con ese identificador por una ejecución anterior, usa otro identificador o limpia únicamente tus datos de prueba, no toda la colección.

Paso 5. Retirar el privilegio temporal

Sal y vuelve como administrador:

```
const s = db.getSiblingDB("curso_seguridad");
s.revokeRolesFromUser(
  "temporalclase",
  [{role:"readWrite",db:"curso_seguridad"}]
);
```

La cuenta conserva su rol de lectura. No hemos bloqueado toda la identidad: hemos retirado una capacidad que dejó de ser necesaria.

Paso 6. Comprobar otra vez la restricción

Conecta de nuevo como `temporalclase` y prueba una inserción con un identificador nuevo:

```
db.getSiblingDB("curso_seguridad").secretos.insertOne({_id:"temporal-prohibido"})
```

Resultado esperado: denegación. Comprueba también que la lectura sigue siendo posible.

La secuencia completa debería ser:

Estado	Leer	Insertar
Inicial	Sí	No
Permiso temporal concedido	Sí	Sí

Estado	Leer	Insertar
Permiso retirado	Sí	No

Paso 7. ¿Qué demuestra realmente el ejercicio?

No basta con que el administrador ejecute `grantRolesToUser` y `revokeRolesFromUser` sin errores. Debemos comprobar **desde la cuenta afectada** que las operaciones permitidas y denegadas corresponden con la política.

Pregunta de evaluación: ¿por qué usarías una cuenta temporal del laboratorio en lugar de ampliar directamente los poderes de `lectorlab` para todas las demás prácticas?

Laboratorio 7 — Leer el estado del servidor sin confundirlo con una auditoría de seguridad

El objetivo

Imagina que un compañero dice: «La conexión falla y no sé si es Docker, MongoDB o mis credenciales». Tu primera tarea será recopilar información de diagnóstico **sin exponer secretos** y sin cambiar permisos al azar.

Paso 1. Comprobar contenedores

Desde PowerShell o Bash en la raíz del proyecto:

```
docker compose ps
```

Anota qué servicios están encendidos. Un contenedor detenido no equivale a una contraseña equivocada: todavía no hemos alcanzado el servidor.

Paso 2. Revisar los últimos mensajes del servicio

```
docker compose logs --tail=80 mongo-seguridad
```

Busca errores de arranque, de inicialización o de configuración. No copies cientos de líneas sin interpretarlas. Anota la hora, el servicio y el fragmento que realmente ayude a comprender el problema.

Protección de información: no pegues claves privadas, contraseñas ni variables de entorno sensibles en tu informe.

Paso 3. Separar tres evidencias

- `docker compose ps` muestra el estado de los contenedores.
- `db.adminCommand({ping:1})` confirma que el servidor responde en una conexión adecuada.
- Una operación de lectura/escritura bajo una identidad concreta muestra si esa acción está autorizada.

Son tres evidencias diferentes. La primera no demuestra quién se ha autenticado; la segunda no concede privilegios; la tercera depende de la cuenta y del recurso consultado.

Paso 4. Repasar un rechazo real

Si `lectorlab` intenta insertar y recibe `Unauthorized`, debemos comprobar primero que sí consigue leer con esa misma sesión. Así aislamos el problema a los permisos de escritura, en vez de culpar a Docker o TLS.

Paso 5. No confundir registros técnicos con auditoría formal

Los logs de un contenedor muestran información operativa. Un sistema completo de auditoría de datos requeriría registrar hechos relevantes con garantías de integridad, retención y consulta. Ver una línea de arranque de `mongod` no demuestra por sí solo quién modificó un documento.

Ejercicio: redacta una respuesta de tres frases a alguien que muestra el log de arranque y afirma: «Ya hemos auditado todos los accesos». Explica qué falta comprobar.

Laboratorio 8 — Caso integrador: diseñar una política y demostrarla

El escenario

Una pequeña organización utiliza MongoDB para gestionar pedidos. Necesita:

1. una aplicación que consulte pedidos;
2. un servicio que registre pedidos nuevos;
3. una persona autorizada para administrar usuarios;
4. conexiones protegidas cuando la red lo exija;
5. una manera de demostrar que las cuentas no pueden realizar operaciones ajenas a su función.

Tu tarea es presentar una propuesta y **evidencias** en lugar de un conjunto de contraseñas y comandos copiados.

Paso 1. Dibujar los actores

Escribe los nombres de los tres actores. Para cada uno especifica:

- recursos que necesita consultar o modificar;
- operaciones imprescindibles;
- operaciones peligrosas que no deberían concederse;
- forma de autenticación adecuada para el ejemplo;
- entorno en el que se realiza la conexión.

La cuenta de administración no debería ser la identidad normal de la aplicación de consulta.

Paso 2. Elegir roles mínimos

Para la aplicación lectora, empieza estudiando `read` sobre la base de datos de pedidos. Para el servicio que registra operaciones, considera `readWrite` u otro rol más preciso si las operaciones realmente lo requieren. Para la administración, separa expresamente la responsabilidad de gestionar usuarios.

No diseñes una política basándote solo en «siempre usamos `root` porque es más fácil».

Paso 3. Proponer cuatro pruebas

Las pruebas deben incluir resultados tanto positivos como negativos:

Actor	Acción	Resultado esperado
Lector	Consultar pedido conocido	Permitido
Lector	Eliminar pedido	Denegado
Escritor	Insertar pedido válido	Permitido

Actor	Acción	Resultado esperado
Escritor	Gestionar roles administrativos	Denegado

Si solo realizas las dos pruebas positivas, aún no sabes si existe una separación efectiva de privilegios.

Paso 4. Relacionar con TLS

Explica por qué una conexión protegida con TLS puede ser necesaria aunque las cuentas tengan contraseñas. Después indica por qué TLS no basta para impedir que un usuario autenticado exceda sus permisos.

Paso 5. Producir un informe comprensible

Tu informe final debe describir el propósito de cada cuenta, sus permisos, los resultados observados en las pruebas y cualquier límite del ejercicio.

No está permitido escribir como conclusión «seguridad comprobada» si no has realizado las operaciones relevantes. Tampoco atribuyas a Community pruebas de LDAP o cifrado nativo que no hemos ejecutado.

Solución de referencia

Una solución coherente separa tres identidades y limita sus privilegios. La cuenta lectora puede consultar y no modificar; la cuenta de escritura puede registrar pedidos, pero no administrar usuarios; la cuenta administrativa queda reservada a tareas especiales. Las conexiones y los secretos se protegen de acuerdo con el contexto. Cada permiso importante se comprueba con una operación real, incluida una denegación esperada.

Criterio de evaluación: otra persona debe poder comprender qué protege tu propuesta, cuál es el límite de cada identidad y qué evidencia respalda tus afirmaciones.

Laboratorio 9 — Reconocer y proteger secretos de configuración

Objetivo y problema

Una aplicación que se conecta a MongoDB puede funcionar correctamente y al mismo tiempo exponer sus credenciales. Imagina que alguien sube a un repositorio público la contraseña administrativa dentro de un archivo de configuración. La aplicación seguirá conectando, pero una persona con acceso a ese fichero podría intentar utilizar la misma identidad.

El objetivo de esta práctica es distinguir **datos públicos de configuración**, **credenciales privadas** y **material criptográfico confidencial**. No intentaremos construir un gestor empresarial de secretos dentro de un curso introductorio.

Paso 1. Reconocer los archivos

Abre PowerShell o Bash en la raíz del repositorio. Debes localizar:

- `compose.yaml`: describe qué contenedores hay y qué parámetros necesitan.
- `.env.example`: muestra los nombres de variables esperados, con valores de demostración.
- `.env`: tu copia local, con las contraseñas que has elegido para la práctica.
- `.gitignore`: indica qué archivos locales no deben añadirse normalmente al control de versiones.

Que el archivo `.env` empiece por un punto no significa que esté cifrado. Es texto de configuración que debe custodiarse.

Paso 2. Crear la copia privada

En PowerShell:

```
Copy-Item .env.example .env
```

En Bash:

```
cp .env.example .env
```

Edita los valores de `MONGO_ADMIN_PASSWORD`, `LAB_READER_PASSWORD` y `LAB_WRITER_PASSWORD`. Utiliza secretos **ficticios y exclusivos de este laboratorio**, nunca contraseñas de correo, empresa u otros sistemas.

Paso 3. Clasificar cinco ejemplos

Dato	¿Publicarlo como ejemplo?	Razón
Nombre ficticio `lectorlab`	Sí	No demuestra identidad por sí solo

Dato	¿Publicarlo como ejemplo?	Razón
Puerto local `27018`	Sí	Describe la infraestructura
Contraseña verdadera	No	Podría permitir iniciar sesión
Certificado público de una CA de prueba	Según contexto	No es la clave privada
`server.pem` que incorpora clave privada	No	Contiene material secreto

El nombre de un usuario y la contraseña que demuestra ser ese usuario **no son lo mismo**.

Paso 4. Comprobar la exclusión del archivo

Si tienes Git instalado, ejecuta:

```
git check-ignore .env
```

El resultado correcto normalmente indica que `.env` está ignorado. Si no tienes Git, abre `.gitignore` en un editor y verifica la exclusión. **Advertencia:** ignorar hoy un fichero no borra una contraseña que ya haya sido publicada en un commit anterior.

Paso 5. Interpretar la sustitución de variables

El archivo Compose puede exigir una variable de contraseña administrativa. Al preparar los servicios, Docker Compose utiliza el valor de tu entorno o de `.env`. Eso evita escribir una contraseña concreta en el archivo compartido, pero **no cifra la variable ni sustituye un sistema profesional de secretos**.

No pegues la salida íntegra de comandos que muestran configuración resuelta si puede contener valores privados.

Paso 6. Resolver un fallo habitual

Un alumno inicia el servidor, luego cambia la contraseña en `.env` y deja de poder entrar.

Explicación: la cuenta administradora se creó en la base cuando se inicializó el volumen por primera vez. Editar después la variable local **no rota automáticamente la credencial almacenada en MongoDB**.

La solución es administrar y coordinar una rotación de contraseña. No elimines el volumen como respuesta instintiva; eso destruiría datos y cuentas de laboratorio.

Evaluación

Explica por qué `.env` no es un almacén cifrado, por qué `.gitignore` no revoca una clave previamente filtrada y por qué una contraseña no debería aparecer ni en el código ni en capturas del terminal.

Laboratorio 10 — Matriz de acceso: qué operaciones deben funcionar y cuáles no

Objetivo

Vamos a verificar que los usuarios de laboratorio no solo se autentican correctamente, sino que tienen permisos diferentes. Una cuenta lectora deberá consultar datos, pero no actualizarlos ni borrarlos. La cuenta escritora sí podrá modificar documentos, sin convertirse por ello en administradora de MongoDB.

Paso 1. Comprobar el servidor y las cuentas

En PowerShell o Bash, desde la raíz del repositorio:

```
docker compose up -d --wait mongo-seguridad
```

Las cuentas `lectorlab` y `escritorlab` deben existir desde el laboratorio 1. Si faltan, completa aquella preparación antes de continuar.

Paso 2. Conectar como lector

```
docker compose exec mongo-seguridad mongosh --username lectorlab --authenticationDatabase
curso_seguridad --password
```

Introduce la contraseña del lector. Dentro de `mongosh`:

```
db.getSiblingDB("curso_seguridad").secretos.findOne({_id:"demo-1"})
```

El documento debe aparecer. Esta es nuestra **prueba positiva**: demuestra que la identidad puede leer el recurso permitido.

Paso 3. Intentar actualizar un documento

```
db.getSiblingDB("curso_seguridad").secretos.updateOne(
  {_id:"demo-1"},
  {$set:{texto:"no autorizado"}}
)
```

Resultado esperado: denegación por falta de permiso de actualización.

Paso 4. Intentar borrar el documento

```
db.getSiblingDB("curso_seguridad").secretos.deleteOne({_id:"demo-1"})
```

También debe rechazarse. Comprueba después mediante `findOne` que el documento original continúa existiendo. La prueba no estaría bien si el mensaje pareciera correcto pero hubiéramos perdido datos.

Paso 5. Conectar como escritor

Sal de `mongosh` escribiendo `exit`. Desde la terminal:

```
docker compose exec mongo-seguridad mongosh --username escritorlab --authenticationDatabase
curso_seguridad --password
```

Dentro del shell, inserta un documento distinto:

```
db.getSiblingDB("curso_seguridad").secretos.insertOne({
  _id:"matriz-escritor",
  texto:"insertado mediante rol readWrite"
})
```

Si ya existe ese identificador porque repetiste la actividad, cambia únicamente el identificador de tu documento ficticio; no confundas un error por duplicado con un error de autorización.

Paso 6. Actualizar y comprobar

```
db.getSiblingDB("curso_seguridad").secretos.updateOne(
  {_id:"matriz-escritor"},
  {$set:{texto:"actualizado por escritor"}}
)
db.getSiblingDB("curso_seguridad").secretos.findOne({_id:"matriz-escritor"})
```

Debe aparecer el texto actualizado. El rol `readWrite` permite escritura sobre esa base, pero **no concede por sí solo privilegios para administrar usuarios**.

Paso 7. Registrar resultados

Identidad	Consulta	Actualiza	Borra
`lectorlab`	Permitida	Denegada	Denegada
`escritorlab`	Permitida	Permitida	Permitida

Anota los mensajes reales y explica por qué dos cuentas autenticadas pueden recibir respuestas distintas al ejecutar la misma operación.

Conclusión correcta: los roles, no el simple hecho de introducir una contraseña válida, limitan qué acciones puede realizar cada identidad.

Laboratorio 11 — Diagnosticar un fallo de autenticación sin modificar privilegios

La situación

Un empleado asegura que está utilizando el nombre de usuario y la contraseña correctos, pero MongoDB no le permite entrar. En muchos equipos, la primera reacción sería cambiarle los permisos o darle una cuenta administrativa para terminar el trabajo. Eso sería un error de diagnóstico.

Vamos a estudiar **la base de autenticación** y el mecanismo por el que MongoDB encuentra la identidad.

Paso 1. Confirmar que el servidor existe

En la terminal del ordenador:

```
docker compose ps
```

Si `mongo-seguridad` está detenido:

```
docker compose up -d --wait mongo-seguridad
```

No tiene sentido investigar contraseñas si no está en marcha el servidor al que deseas conectarte.

Paso 2. Elegir una cuenta conocida

Usa `lectorlab`, creado en `curso_seguridad` en la primera práctica. Necesitas conocer su contraseña **de laboratorio**, guardada en tu configuración personal, sin escribirla en el documento de entrega.

Paso 3. Probar una base de autenticación errónea

Desde PowerShell o Bash:

```
docker compose exec mongo-seguridad mongosh --username lectorlab --authenticationDatabase admin
--password
```

Introduce la contraseña que crees correcta.

Resultado esperado: error de autenticación. En este laboratorio la identidad `lectorlab` está registrada en `curso_seguridad` y no en `admin`.

El comando no significa «solicita los datos de admin»: indica **dónde debe buscar el servidor la cuenta que presentamos**.

Paso 4. Corregir el contexto, no los permisos

Repite la conexión con la base correcta:

```
docker compose exec mongo-seguridad mongosh --username lectorlab --authenticationDatabase
curso_seguridad --password
```

Debes poder entrar. Ahora, dentro de `mongosh`:

```
db.getSiblingDB("curso_seguridad").secretos.findOne({_id:"demo-1"})
```

Debe aparecer el documento de lectura. **Observa:** hemos resuelto la autenticación sin añadir ningún permiso de escritura.

Paso 5. Provocar después una denegación real de permiso

En la misma sesión del lector, intenta:

```
db.getSiblingDB("curso_seguridad").secretos.insertOne({_id:"diagnostico-no-permitido"})
```

Ahora el resultado esperado es **denegación de autorización**. Hemos llegado al servidor, autenticado la cuenta y recibido rechazo únicamente para una operación que supera sus privilegios.

Paso 6. Comparar los tres estados

Situación	¿Existe conexión al servidor?	¿Identidad autenticada?	¿Operación permitida?
Contenedor no arrancado	No	No	No se evalúa
Base de autenticación equivocada	Sí	No	No se evalúa
Lector intenta escribir	Sí	Sí	No

Esta tabla muestra por qué no se deben resolver todos los fallos dando el rol `root`.

Paso 7. Explicación escrita

Redacta una respuesta para soporte técnico:

> «La conexión con el servidor se había establecido, pero la cuenta se estaba buscando en una base de autenticación distinta de aquella donde fue creada. Corrigiendo ese parámetro, pudo consultar los datos; las escrituras continúan denegadas por diseño».

Si puedes explicar esta distinción sin copiar el texto, has comprendido tres capas fundamentales de la seguridad.

Laboratorio 12 — Caducidad de sesiones: TTL no sustituye la decisión de acceso

Qué problema plantea

Una aplicación guarda un documento para cada sesión temporal. Cuando una sesión caduca, no debe aceptarse como válida. MongoDB puede usar un índice TTL para borrar el registro eventualmente, pero la limpieza **no es inmediata** y no debe convertirse en la única regla de autorización.

Paso 1. Preparar dos sesiones ficticias

Conéctate como `adminlab` a `mongo-seguridad` y abre `mongosh`. Dentro del shell:

```
const d = db.getSiblingDB("curso_seguridad");
d.sesiones_clase.drop();
d.sesiones_clase.insertMany([
  {_id:"caducada",usuario:"alumno1",expiraEn:new Date(Date.now()-60000)},
  {_id:"vigente",usuario:"alumno2",expiraEn:new Date(Date.now()+3600000)}
]);
```

La primera fecha representa un minuto antes del momento actual; la segunda, una hora después. Son datos completamente ficticios. El `drop` elimina exclusivamente la colección `sesiones_clase`.

Paso 2. Comprobar la expiración al consultar

```
d.sesiones_clase.find({
  _id:"caducada",
  expiraEn:{$gt:new Date()}
}).toArray()
```

Resultado esperado: array vacío. Aunque el registro todavía exista, su fecha de validez ya ha pasado. Por tanto, una condición temporal adecuada no lo considera vigente.

Paso 3. Comprobar la sesión futura

```
d.sesiones_clase.find({
  _id:"vigente",
  expiraEn:{$gt:new Date()}
}).toArray()
```

Debe aparecer el documento `vigente`.

Paso 4. Crear TTL como limpieza de almacenamiento

```
d.sesiones_clase.createIndex(
  {expiraEn:1},
  {expireAfterSeconds:0}
)
```

La opción `expireAfterSeconds:0` expresa que la fecha `expiraEn` ya contiene el instante de caducidad. El monitor periódico borrará documentos expirados cuando corresponda. **No garantiza su eliminación exactamente en el primer milisegundo después de vencer.**

Paso 5. Interpretar la diferencia

Consulta directamente el documento caducado:

```
d.sesiones_clase.findOne({_id:"caducada"})
```

Puede permanecer temporalmente y después desaparecer. Lo importante es que **la consulta de validez del paso 2 ya lo había rechazado**.

Una política equivocada sería «si existe el documento, permitir la operación». Una política más cuidadosa verificará identidad, validez temporal, revocación y permisos según el diseño de la aplicación.

Paso 6. Completar la explicación

Indica qué hace cada uno de los siguientes mecanismos:

- Autenticación: _____.
- Autorización: _____.
- Comprobación de `expiraEn`: _____.
- TTL: _____.

Si has entendido por qué son cuatro controles diferentes, no cometerás el error de tratar un índice como si fuera una política completa de sesiones.

Laboratorio 13 — Informe de evidencias: qué hemos probado y qué no

La conclusión no puede ser más grande que las pruebas

Después de ejecutar varios ejercicios, alguien escribe «la base de datos está completamente protegida». Esa frase no explica frente a qué amenaza, con qué configuración ni mediante qué comprobación se llega a la conclusión.

Vamos a producir un informe breve, legible y **honesto sobre sus límites**.

Paso 1. Inventariar los servidores usados

Servicio	Uso	¿Has completado sus ejercicios?
`mongo-indices`	Consultas y estructuras de acceso	____
`mongo-seguridad`	SCRAM y permisos de roles	____
`mongo-tls`	TLS y certificados X.509	____

No marques X.509 como probado si solamente ejecutaste una conexión TLS con `ping`.

Paso 2. Resumir autenticación y autorización

Para cada identidad ensayada, anota:

- usuario y base de autenticación;
- lectura o escritura intentada;
- resultado esperado;
- resultado observado;
- causa probable si no coinciden.

No escribas contraseñas ni copies claves privadas. La evidencia puede ser verificable sin filtrar secretos.

Paso 3. Resumir los controles TLS

Distingue al menos:

1. Conexión sin TLS rechazada.
2. Conexión con TLS y CA verificada.
3. Autenticación de cliente mediante X.509, si realizaste el ejercicio.
4. Lectura permitida a esa identidad, cuando corresponda.
5. Escritura denegada por un rol de solo lectura.

Cada paso demuestra una propiedad diferente. Un `ping` positivo no sustituye todas estas verificaciones.

Paso 4. Señalar capacidades fuera del alcance de Community

En los manuales aparecen como contenido conceptual LDAP empresarial y el cifrado nativo de MongoDB en reposo. **No se han ejecutado esas funciones sobre nuestro contenedor Community**. Debes reconocerlo expresamente en tu informe y no presentarlas como pruebas superadas.

Paso 5. Preparar una conclusión proporcional

Una conclusión aceptable:

> «En el servidor de laboratorio se verificó que una cuenta con rol de lectura podía consultar datos, pero no insertarlos. También se ensayó la exigencia de TLS. Estas pruebas respaldan esos controles concretos y no constituyen una evaluación integral de seguridad de producción».

Una conclusión inaceptable:

> «MongoDB está protegido porque todos los comandos terminaron».

Paso 6. Evaluación entre compañeros

Entrega el informe a otra persona y pídele responder:

- qué servidor se utilizó;
- qué identidad realizó la operación;
- qué acción se intentó;
- qué resultado se esperaba;
- qué resultado se observó;
- qué controles quedaron sin probar.

Si no puede responder, mejora la trazabilidad de tus afirmaciones. El propósito de esta última práctica es aprender a **justificar conclusiones**, no acumular documentos burocráticos.

Laboratorio 14 — Interpretar certificados TLS sin confundir servidor y cliente

Una misma tecnología, funciones diferentes

Cuando utilizamos TLS en MongoDB aparecen varios archivos que pueden parecer similares: certificados, claves privadas, autoridades certificadoras y paquetes PEM. Un principiante puede llegar a conectar copiando comandos sin saber qué fichero está entregando.

Esta práctica se centra en **comprender qué contiene cada archivo y qué identidad representa**. No necesitas implementar algoritmos criptográficos.

Paso 1. Preparar certificados nuevos para un entorno desechable

Desde Bash en la raíz del repositorio:

```
bash scripts/generar-certificados.sh
```

El script utiliza OpenSSL para crear una CA y certificados de servidor y de cliente **temporales, exclusivamente docentes**. Si ya tienes certificados que estás utilizando en una sesión activa, no los sustituyas sin comprender que el servidor puede necesitar reiniciarse con el nuevo material.

La carpeta `certs` queda fuera del repositorio Git por contener claves privadas.

Paso 2. Identificar los archivos

Localiza:

Archivo	Función
`ca.crt`	Certificado público de la autoridad de prueba
`server.crt`	Certificado del servidor
`server.key`	Clave privada correspondiente al servidor
`server.pem`	Paquete utilizado por el servidor en el laboratorio
`client.crt`	Certificado de la identidad del alumno
`client.key`	Clave privada del alumno
`client.pem`	Paquete usado para autenticación de cliente

No publiques archivos `.key` ni paquetes PEM que incorporen esas claves. El hecho de que una práctica sea efímera no convierte una clave privada en material inocuo.

Paso 3. Leer un certificado sin mostrar la clave

En Bash:

```
openssl x509 -in certs/server.crt -noout -subject -issuer -dates
```

Interpreta `subject` como la identidad a la que se emitió el certificado, `issuer` como la autoridad que lo firmó y las fechas como el intervalo de validez.

Este comando **no imprime la clave privada**. Es suficiente para investigar esos metadatos.

Paso 4. Leer el certificado del alumno

```
openssl x509 -in certs/client.crt -noout -subject -issuer -dates
```

Compara con el certificado del servidor. Deben representar identidades distintas: uno corresponde al servicio MongoDB; otro a un cliente que podrá utilizar X.509.

En el laboratorio el sujeto del alumno contiene un DN con `CN=alumno-x509`. Un DN no es una contraseña. Es una descripción de la identidad del certificado que el servidor puede asociar a un usuario y sus roles.

Paso 5. Verificar firmas de la CA

```
openssl verify -CAfile certs/ca.crt certs/server.crt certs/client.crt
```

Resultado esperado: confirmación de verificación correcta de ambos certificados con esa CA de laboratorio.

¿Qué hemos comprobado? La validez criptográfica de las firmas respecto a la autoridad indicada, bajo las condiciones que verifica OpenSSL. **No hemos demostrado todavía que la cuenta del alumno pueda leer o escribir datos**.

Paso 6. Comprobar el nombre del servidor

El certificado del servidor incluye nombres que se esperan para el entorno de prueba. Puedes inspeccionar su información ampliada:

```
openssl x509 -in certs/server.crt -noout -text
```

Busca la extensión `Subject Alternative Name`. Debe contener nombres o direcciones para las que se preparó la conexión, como `localhost` o el nombre del servicio según el archivo de generación.

La verificación del nombre del servidor es esencial para evitar aceptar un certificado válido para **otro** equipo.

Paso 7. Probar sin TLS y con TLS

Con la instancia `mongo-tls` preparada mediante Compose:

```
docker compose up -d --wait mongo-tls
```

Primero intenta un ping sin TLS:

```
docker compose exec -T mongo-tls mongosh --quiet --host localhost --eval
'db.adminCommand({ping:1})'
```

Debe fallar: el servidor exige TLS.

Ahora utiliza la CA:

```
docker compose exec -T mongo-tls mongosh --quiet --host localhost --tls --tlsCAFile /certs/
ca.crt --eval 'printjson(db.adminCommand({ping:1}))'
```

Resultado esperado: `ok:1`.

Paso 8. Explicar qué NO sabemos todavía

Una conexión TLS con `ping` correcto no demuestra que el cliente esté autorizado a leer `curso_cert`. Tampoco demuestra que se haya autenticado por X.509, porque todavía no hemos presentado el certificado de alumno con ese mecanismo.

La práctica siguiente puede utilizar el script `scripts/probar-seguridad.sh` para preparar esa identidad, asignarle un rol de solo lectura y probar acceso permitido y escritura rechazada.

Preguntas de comprensión

1. ¿Por qué el certificado de la CA no debe confundirse con la clave privada del servidor?
2. ¿Qué significa que el certificado tenga una fecha de caducidad?
3. ¿Qué protege TLS y qué no protege?
4. ¿Por qué `ping` no es una prueba completa de privilegios?
5. ¿Qué diferencia existe entre certificar al servidor y autenticar al cliente?

Laboratorio 15 — Aprender a reinicializar un entorno de prueba sin destruir datos por accidente

El problema más peligroso de un tutorial mal explicado

Un alumno modifica una contraseña, vuelve a ejecutar un script de creación de usuarios y recibe «usuario ya existe». Al buscar una solución encuentra una respuesta que recomienda ejecutar `docker compose down --volumes`. Tras hacerlo, desaparecen sus cuentas y documentos.

¿Por qué ocurrió? Porque la orden elimina los **volúmenes de datos**, no solamente el contenedor en ejecución.

Este laboratorio explica la persistencia y propone un procedimiento de diagnóstico antes de borrar algo.

Paso 1. Reconocer tres operaciones de Docker Compose

Orden	Qué hace de forma resumida	¿Elimina datos de volúmenes con nombre?
`docker compose stop`	Detiene los servicios seleccionados	No
`docker compose down`	Retira contenedores y redes del proyecto	No, normalmente conserva volúmenes con nombre
`docker compose down --volumes`	Retira también volúmenes del proyecto	Sí

No confundas «parar el servidor» con «recrear su almacenamiento desde cero».

Paso 2. Comprobar el inventario de contenedores

```
docker compose ps
```

La instancia `mongo-seguridad` debe aparecer en ejecución para seguir con el experimento. No necesitas copiar contraseñas a la salida.

Paso 3. Comprobar un documento de control

Conecta como administrador desde la terminal:

```
docker compose exec mongo-seguridad mongosh --username adminlab --authenticationDatabase admin
--password
```

Dentro de `mongosh`:

```
db.getSiblingDB("curso_seguridad").secretos.findOne({_id:"demo-1"})
```

Guarda únicamente el resultado esperado (presente/ausente) y un identificador de control. No uses datos reales.

Paso 4. Detener sin destruir

Sal del shell y ejecuta en la terminal:

```
docker compose stop mongo-seguridad
```

El contenedor se detiene, pero los datos siguen en su volumen con nombre.

Paso 5. Reanudar y comprobar

```
docker compose up -d --wait mongo-seguridad
```

Vuelve a autenticarte y consulta `demo-1`. **Resultado esperado:** sigue existiendo.

Explicación: detener el proceso no destruye automáticamente la información almacenada en el volumen persistente.

Paso 6. ¿Por qué no repetimos sin pensar la creación de usuarios?

Si `lectorlab` ya existe, intentar `createUser` otra vez con ese mismo nombre puede producir un error de duplicidad de usuario. No se trata de un fallo de red.

Un procedimiento adecuado comienza comprobando su existencia desde una identidad autorizada:

```
db.getSiblingDB("curso_seguridad").getUser("lectorlab")
```

Si existe, decide si realmente necesitas modificar esa cuenta, actualizar su contraseña o conservar su estado. No borres todo el almacenamiento para corregir un problema localizado.

Paso 7. Restauración y copia no son lo mismo que reinicialización

El laboratorio permite reconstruir datos ficticios, pero eso no equivale a restaurar una copia de seguridad de producción. Una restauración exige identificar el conjunto recuperado, verificar coherencia y comprobar que las aplicaciones vuelven a funcionar.

Pregunta profesional: si una empresa pierde una colección real, ¿sería aceptable ejecutar el script de carga de ventas ficticias y declarar que los datos se han recuperado? No: estaríamos creando otros documentos, no restaurando los originales.

Paso 8. Plan de reinicio responsable

Antes de ejecutar una operación destructiva:

1. Identifica qué colección o cuenta quieres corregir.
2. Comprueba qué servicio y volumen están implicados.
3. Decide si hay datos que debas conservar.
4. Utiliza la operación menos destructiva que resuelva la necesidad.

5. Anota cómo comprobarás que el resultado es correcto.

No ejecutaremos `down --volumes` como parte obligatoria de esta práctica. La finalidad es comprender las consecuencias sin destruir los datos que ya creaste.

Autoevaluación

¿Por qué un volumen persistente es útil para un alumno que detiene el ordenador al terminar la clase? ¿Por qué la misma persistencia obliga a distinguir «cambié una variable de entorno» de «cambié el usuario almacenado en MongoDB»? ¿Qué evidencia exigirías antes de afirmar que se restauró una base de datos?

Laboratorio 16 — Ejecutar el banco completo de seguridad y entender cada resultado

La diferencia entre «el script terminó» y «he aprendido qué demuestra»

En algunas clases se ejecuta un archivo de comprobación que imprime una lista de mensajes verdes. El alumno considera que ha aprendido seguridad porque no apareció ningún error. Eso es insuficiente: podría no saber qué control se probó ni qué debe significar una denegación.

En este laboratorio utilizaremos el procedimiento automático `scripts/probar-seguridad.sh`, pero prepararemos antes una **tabla de hipótesis**, interpretaremos los mensajes y comprobaremos las limitaciones de la prueba.

Paso 1. Reconocer las tres instancias

El proyecto contiene:

- `mongo-indices`, usado para consultas e índices de ventas;
- `mongo-seguridad`, con cuentas SCRAM y roles;
- `mongo-tls`, que exige TLS y permite autenticación X.509.

El banco de seguridad utiliza principalmente las dos últimas. No debes ejecutar los experimentos sobre un MongoDB real que hayas encontrado en el ordenador.

Paso 2. Preparar un entorno desechable

Revisa primero si esos contenedores ya contienen datos que quieras conservar. El banco realiza operaciones de preparación de usuarios y colecciones; ciertos pasos están pensados para una instancia recién inicializada.

No ejecutes la prueba completa sobre un volumen con usuarios ya creados sin entender qué comandos intentarán crearlos otra vez. Para repetirla desde cero, el formador puede utilizar un entorno Docker dedicado y desechable, como hace GitHub Actions en cada job.

Paso 3. Preparar credenciales de prueba

En el archivo local `.env` configura `MONGO_ADMIN_PASSWORD`, `LAB_READER_PASSWORD` y `LAB_WRITER_PASSWORD` con valores exclusivamente docentes. Los valores no deben ser credenciales de producción.

Para el script Bash, las variables deben estar disponibles en el entorno del proceso. Si utilizas Bash y controlas el contenido de `.env` puedes revisar sus líneas y cargarlo cuidadosamente; el formador debe explicar que ejecutar un archivo mediante `source` solo es seguro si confiamos en su contenido.

No publiques el resultado de comandos que muestren contraseñas.

Paso 4. Generar certificados temporales

```
bash scripts/generar-certificados.sh
```

Este archivo genera la CA local, el certificado de servidor y el certificado del alumno. Los certificados no se reutilizarán para otros proyectos; tienen una vigencia reducida y están diseñados para el laboratorio.

Paso 5. Iniciar los dos servicios

```
docker compose up -d --wait mongo-seguridad mongo-tls
docker compose ps
```

Ambos deben estar preparados. Si alguno falla, revisa los logs del servicio correspondiente. No conviertas un fallo de certificado al arrancar el servidor en un supuesto error de contraseña del usuario lector.

Paso 6. Escribir los resultados esperados ANTES de probar

Completa la segunda columna:

Prueba	¿Permitida o denegada?	Razón
Leer sin autenticar	_____	_____
Leer con contraseña SCRAM incorrecta	_____	_____
Leer con `lectorlab`	_____	_____
Insertar con `lectorlab`	_____	_____
Insertar con `escritorlab`	_____	_____
Conectar a `mongo-tls` sin TLS	_____	_____
Conectar con TLS y CA válida	_____	_____
Leer como alumno X.509 autorizado	_____	_____
Escribir como alumno X.509 de solo lectura	_____	_____

Si no puedes anticipar cada respuesta, vuelve a la teoría. Ejecutar primero y copiar después el resultado esperado elimina el valor didáctico del experimento.

Paso 7. Ejecutar el procedimiento de verificación

Con las variables locales disponibles y los certificados generados:

```
bash scripts/probar-seguridad.sh
```

El script prepara el entorno y comprueba tanto operaciones permitidas como errores esperados. Si el resultado incluye una denegación prevista, no significa que el banco haya fallado. Los mensajes `[OK]` indican que el resultado coincide con la hipótesis declarada en el propio script.

Paso 8. Identificar un error por conexión no preparada

Si falla antes de crear o autenticar usuarios, revisa:

- si `mongo-seguridad` se inició con el archivo `.env` correcto;
- si existe una cuenta administrativa inicial creada con otra contraseña;
- si los certificados de la instancia TLS están presentes y accesibles;
- si el contenedor es realmente nuevo cuando el script espera crear `admincert`.

No resuelvas todos los problemas borrando volúmenes inmediatamente. Primero identifica qué recurso se vería afectado y qué datos perderías.

Paso 9. Interpretar los resultados de identidad

Si se rechaza una contraseña errónea, MongoDB está negando autenticación. Si `lectorlab` logra leer y después se rechaza su inserción, es RBAC el que impide una operación no autorizada.

Estas dos denegaciones se parecen superficialmente en que ambas producen errores, pero pertenecen a capas distintas.

Paso 10. Interpretar TLS y X.509

La conexión sin TLS debe ser rechazada por el servicio `mongo-tls`. La conexión que verifica la CA permite comprobar el canal. Después, la identidad X.509 puede autenticar al cliente mediante su certificado, y el rol asignado determina qué puede consultar.

Una escritura rechazada **después de autenticarse por X.509** no significa que el certificado sea incorrecto. Puede significar exactamente lo contrario: la identidad fue aceptada, pero sus permisos no incluyen insertar.

Paso 11. Redactar la conclusión

No entregues la salida completa sin comentario. Resume:

1. Qué mecanismos fueron puestos a prueba.
2. Qué operaciones positivas funcionaron.
3. Qué operaciones negativas fueron rechazadas.
4. Qué resultado muestra la distinción entre autenticación y autorización.
5. Qué aspectos NO demuestra este banco comunitario.

Solución orientativa

«En el servidor protegido se rechazó la lectura anónima y una contraseña incorrecta. Una cuenta de lectura pudo consultar el documento preparado, pero no insertarlo. La cuenta de escritura sí pudo realizar su operación autorizada. La instancia TLS rechazó una conexión sin cifrado y permitió otra que verificó su CA. El certificado de cliente X.509 identificó una cuenta con permiso de lectura, no de escritura. Estas pruebas no acreditan el cifrado nativo en reposo ni una integración LDAP empresarial».

Esa conclusión tiene un alcance concreto, porque cada frase corresponde a una operación observada.

Laboratorio 17 — Diseñar una respuesta a un acceso indebido sin borrar las evidencias

El caso

En los registros de una aplicación aparece un intento de lectura de datos desde una cuenta que no debería consultar esa colección. Una persona propone solucionar el problema borrando inmediatamente todos los documentos, cambiando indiscriminadamente roles y reiniciando la infraestructura.

Es importante aprender que **un incidente requiere investigar su causa y contener sus efectos**, no destruir todo lo que ayuda a comprender qué ocurrió.

Esta actividad es un ejercicio de análisis y diseño. No vamos a simular un ataque real ni a manipular un servidor fuera del laboratorio.

Paso 1. Reunir hechos antes de concluir

Imagina estos datos:

- La instancia `mongo-seguridad` responde.
- La cuenta `lectorlab` puede leer `curso_seguridad.secretos`.
- Una cuenta distinta intenta la misma consulta y recibe `Unauthorized`.
- No tenemos todavía evidencia de que se hayan extraído datos.

¿Qué podemos afirmar? Que el servidor denegó la operación concreta observada. **No podemos afirmar** que no existiera ningún otro intento o que el sistema entero sea invulnerable.

Paso 2. Separar hechos y sospechas

Afirmación	¿Hecho o inferencia?
La operación concreta recibió una denegación	Hecho observado
Nadie accedió nunca a otra colección	No demostrado
La cuenta carece de permisos para esta operación	Compatible con la evidencia; hay que revisar roles
Todas las copias de seguridad están protegidas	No demostrado

El objetivo no es dramatizar el incidente, sino aprender a escribir un diagnóstico que otra persona pueda verificar.

Paso 3. Identificar qué se debe preservar

Un informe técnico debe conservar, según el procedimiento de la organización:

- instante de la observación;
- identidad o servicio implicado;

- operación solicitada;
- colección y base;
- resultado de la operación;
- configuración relevante de permisos, sin publicar secretos;
- registros necesarios para investigar.

No modifiques o elimines indiscriminadamente los logs para obtener una pantalla limpia. Esa acción podría eliminar pistas relevantes.

Paso 4. Priorizar controles

Si el problema es un acceso desde una red no autorizada, revisa exposición de puertos y reglas de red. Si alguien usa una cuenta con exceso de permisos, revisa RBAC y la gestión de credenciales. Si la comunicación carece de TLS, la solución está en el canal y la verificación de certificados.

Diferentes causas requieren diferentes controles. No otorgues privilegios adicionales para «arreglar» un rechazo correctamente producido.

Paso 5. Proponer dos pruebas posteriores

Después de cualquier corrección, debes comprobar:

- **prueba positiva:** la operación legítima sigue funcionando;
- **prueba negativa:** la operación que debía impedirse sigue siendo rechazada.

Ejemplo: después de reducir permisos, `lectorlab` debe continuar leyendo `demo-1`, pero no debe poder insertarlo ni eliminarlo.

Paso 6. Explicar los límites

Una prueba con datos ficticios puede enseñar a investigar errores de permisos, pero no sustituye procedimientos de respuesta a incidentes, obligaciones legales, retención forense ni evaluación de sistemas empresariales.

Preguntas finales

1. ¿Por qué un error `Unauthorized` puede ser evidencia favorable?
2. ¿Por qué no es correcto afirmar que nunca hubo otro acceso?
3. ¿Qué diferencia hay entre contener un problema de red y revocar una identidad?
4. ¿Por qué hay que volver a probar tanto una operación permitida como una denegada?
5. ¿Qué riesgos introduces si eliminas todos los registros antes de investigar?

Resultado esperado: una respuesta razonada, no una secuencia de comandos destructivos.

Laboratorio 18 — Interpretar el resultado de una conexión sin confundir sus capas

Nuestro problema

Una persona abre `mongosh` y consigue ejecutar `ping`. Después intenta consultar una colección y recibe una denegación. Considera que MongoDB no funciona. Vamos a demostrar por qué esas dos observaciones **no son contradictorias**.

Paso 1. Definir las cuatro comprobaciones

Para un servidor que protege documentos hay cuatro preguntas:

1. ¿El servicio está en ejecución y es alcanzable?
2. ¿El cliente y el servidor han negociado correctamente el canal?
3. ¿El servidor conoce la identidad presentada?
4. ¿Esa identidad tiene permiso para la operación concreta?

No necesitas dominar la criptografía para reconocer que una respuesta positiva a la primera pregunta no resuelve automáticamente las restantes.

Paso 2. Comprobar disponibilidad

En PowerShell o Bash:

```
docker compose ps
```

Si `mongo-seguridad` está detenido, arráncalo:

```
docker compose up -d --wait mongo-seguridad
```

Resultado esperado: el servicio aparece en ejecución. Esto verifica el estado de Docker, no los permisos de una cuenta.

Paso 3. Comprobar respuesta del servidor

Conecta como `adminlab` mediante el comando de la primera práctica. Dentro de `mongosh`:

```
db.adminCommand({ping:1})
```

Una respuesta con `ok:1` muestra que el servidor responde a esa orden. No deduzcas que cualquier usuario podrá consultar o modificar cualquier colección.

Paso 4. Comprobar autenticación de una cuenta de lectura

Cierra el shell administrativo. Desde PowerShell o Bash:

```
docker compose exec mongo-seguridad mongosh --username lectorlab --authenticationDatabase
curso_seguridad --password
```

Introduce la contraseña del lector. Si falla aquí, revisa la identidad, la contraseña y la base de autenticación, antes de estudiar permisos de escritura.

Paso 5. Comprobar una lectura

En la sesión del lector:

```
db.getSiblingDB("curso_seguridad").secretos.findOne({_id:"demo-1"})
```

Resultado esperado: documento de prueba. La operación confirma que la cuenta ha conseguido consultar el recurso previsto.

Paso 6. Intentar una escritura que no se permite

```
db.getSiblingDB("curso_seguridad").secretos.insertOne({
  _id:"intento-sin-permiso-clase",
  texto:"prueba negativa"
})
```

Resultado esperado: denegación de autorización.

Explica por qué el rechazo no contradice que `ping` o `findOne` funcionaran. La cuenta ha demostrado identidad y puede leer; no tiene permiso para insertar.

Paso 7. Preparar una matriz de resultados

Comprobación	Control	Resultado esperado
Servicio healthy	Disponibilidad	Positivo
`ping`	Comunicación	Positivo
Inicio de sesión lector	Autenticación	Positivo
`findOne`	Autorización de lectura	Positivo
`insertOne` lector	Autorización de escritura	Denegado

Aprendizaje: cada prueba debe estar vinculada a una propiedad concreta del sistema. Una comprobación de disponibilidad no sustituye una política de acceso.

Laboratorio 19 — Diseñar pruebas que impidan confundir usuarios y servicios

Una pregunta de aplicación

Imagina tres identidades:

- una cuenta lectora para visualizar pedidos;
- una cuenta escritora para registrar nuevos pedidos;
- una cuenta administrativa reservada a gestión.

Si las tres utilizan los mismos privilegios, una prueba en la que todo funciona no demostrará que haya separación de responsabilidades.

Paso 1. Formular las operaciones mínimas

La aplicación lectora necesita consultar. La escritora necesita registrar pedidos. La administración prepara usuarios y permisos.

Escribe:

- Cuenta lectora: operaciones obligatorias: _____.
- Cuenta escritora: operaciones obligatorias: _____.
- Administración: operaciones reservadas: _____.

No incluyas permisos «por si acaso». La finalidad es justificar cada capacidad.

Paso 2. Identificar qué no debe hacer el lector

Un rol `read` sobre `curso_seguridad` no debería permitir `insertOne`, `updateOne` ni `deleteOne`. Tampoco debería administrar identidades.

Si la aplicación de informes intenta esas acciones, puede ser que su propio código se esté excediendo respecto a su función.

Paso 3. Construir una prueba positiva y una negativa

Para `lectorlab`:

- positiva: consultar `demo-1`;
- negativa: intentar insertar un documento ficticio.

Para `escritorlab`:

- positiva: insertar un documento ficticio;
- negativa: intentar una tarea de administración que su rol de aplicación no concede.

El ejercicio no exige ejecutar una operación administrativa destructiva. Debe quedar claro **qué permisos están fuera del rol**.

Paso 4. ¿Por qué no conceder permisos administrativos?

Dar permisos más amplios puede ocultar el error inmediato, pero aumenta las consecuencias posibles de un fallo de aplicación o de una credencial expuesta.

Lo correcto es determinar si la operación pertenece a la función del proceso. Si una pantalla de informes quiere gestionar usuarios, quizás hemos mezclado responsabilidades que deberían estar separadas.

Paso 5. Revisar un cambio temporal de rol

Si una cuenta necesita escribir durante una tarea excepcional, esa ampliación debería justificarse y retirarse después. El laboratorio de concesión y revocación de roles demuestra cómo se puede ensayar el proceso.

No basta con comprobar que después de conceder un permiso funciona: debemos volver a probar la denegación cuando el permiso deja de ser necesario.

Paso 6. Entrega razonada

Escribe una respuesta de seis frases:

1. Qué hace la cuenta lectora.
2. Qué hace la cuenta escritora.
3. Qué operaciones están reservadas a administración.
4. Qué prueba positiva realizaste.
5. Qué prueba negativa realizaste.
6. Cómo comprobarías que una retirada de privilegios se aplicó.

La respuesta debe permitir entender por qué los roles se diseñan a partir de responsabilidades y no de nombres agradables.

Laboratorio 20 — Inspeccionar usuarios y roles en lugar de confiar en su nombre

Objetivo

Un usuario llamado `soloLectura` podría tener permisos de escritura si alguien le asignó un rol inadecuado. Del mismo modo, una cuenta llamada `admin` podría no ser realmente administradora.

Los nombres no son pruebas de autorización. Vamos a inspeccionar las definiciones reales de las cuentas y los roles del laboratorio.

Paso 1. Conectarse con una identidad autorizada

Desde PowerShell o Bash, con el servicio preparado:

```
docker compose exec mongo-seguridad mongosh --username adminlab --authenticationDatabase admin
--password
```

Introduce la contraseña administrativa. Dentro de `mongosh`:

```
const curso = db.getSiblingDB("curso_seguridad");
```

No vamos a modificar documentos de ventas. Trabajaremos con las identidades del servidor protegido.

Paso 2. Consultar el usuario lector

```
curso.getUser("lectorlab")
```

El resultado debe mostrar información sobre esa cuenta, incluidos sus roles asignados. Busca `role:"read"` y `db:"curso_seguridad"`.

Si el resultado es nulo o no aparece esa cuenta, probablemente no preparaste el entorno del laboratorio 1 o estás consultando otra instancia/base. **No inventes una salida que no existe.**

Paso 3. Consultar el escritor

```
curso.getUser("escritorlab")
```

Compara el resultado con el anterior. La diferencia importante debe ser `readWrite` frente a `read`. Eso explica por qué una inserción permitida para uno debe estar denegada para el otro.

Paso 4. Examinar privilegios efectivos

Con los privilegios adecuados puedes solicitar más información sobre una cuenta:

```
curso.getUser("lectorlab",{showPrivileges:true})
```

Examina la estructura que describe privilegios y roles. El formato puede ser más extenso de lo esperado. No intentes memorizar todo el JSON: busca **recursos y acciones**.

La pregunta clave es:

- ¿Sobre qué base o colección actúa el rol?
- ¿Qué operaciones permite?
- ¿Hay roles adicionales heredados que amplíen sus poderes?

Paso 5. Distinguir roles asignados de privilegios efectivos

Una cuenta puede tener varios roles. Los permisos efectivos pueden incluir acciones derivadas de más de una asignación y de roles heredados. Por eso no basta con observar que aparece el nombre `read` si también existen asignaciones más amplias.

En el laboratorio inicial las cuentas son sencillas. La práctica es aprender una técnica de inspección que seguirá siendo útil cuando los permisos sean más complejos.

Paso 6. Comprobarlo mediante una operación real

Cierra la sesión de administrador y entra como `lectorlab`. Consulta `demo-1` y después intenta insertar un registro de prueba.

Si el rol inspeccionado era de lectura, debe aparecer una lectura permitida y una escritura denegada. **La definición y el comportamiento observado deben concordar.**

Paso 7. Resolver una discrepancia

Supongamos que `getUser` muestra permisos de escritura cuando esperabas lectura únicamente. No conviertas el resultado en un simple error del manual. Examina si:

- el usuario fue modificado en una práctica previa;
- se le concedió temporalmente otro rol;
- te conectaste a una base o servidor diferentes;
- se reutilizó un volumen de laboratorio que ya contenía usuarios anteriores.

La infraestructura persistente mantiene datos y cuentas entre reinicios. Esa es una ventaja, pero obliga a conocer el estado inicial.

Preguntas de evaluación

1. ¿Por qué el nombre `soloLectura` no demuestra nada sobre los privilegios?
2. ¿Qué diferencia hay entre mirar un rol asignado y comprobar una operación real?
3. ¿Qué ocurre si una cuenta tiene tanto `read` como un rol que concede escritura?
4. ¿Por qué un contenedor recién iniciado puede conservar permisos creados ayer?

Laboratorio 21 — Un informe final de seguridad que pueda reproducirse

El reto

Tu formador te pide entregar una pequeña investigación del laboratorio. No quiere una lista de comandos copiados ni una captura con cinco mensajes verdes. Quiere saber **qué se probó, cómo se comprobó y qué significan los resultados**.

Trabajarás con un servidor y una identidad de la práctica, sin introducir datos reales.

Paso 1. Escribir el escenario en lenguaje natural

Ejemplo:

> «La colección ficticia secretos contiene un registro de demostración. La cuenta lectorlab debe poder leerlo, pero no debe modificarlo».

Esta frase expresa **la necesidad de seguridad**. El código que ejecutaremos después debe comprobarla.

Paso 2. Identificar el contexto

Escribe:

- Servicio Docker: `mongo-seguridad`.
- Base de datos: `curso_seguridad`.
- Colección: `secretos`.
- Identidad principal: `lectorlab`.
- Base de autenticación: `curso_seguridad`.

Si alguno de estos datos es diferente en tu ejecución, anótalo en lugar de fingir que coincide.

Paso 3. Formular hipótesis independientes

Hipótesis A: el servidor está en ejecución.

Hipótesis B: la cuenta puede demostrar su identidad.

Hipótesis C: la cuenta puede consultar el documento `demo-1`.

Hipótesis D: la cuenta no puede insertar.

Cada hipótesis necesita una comprobación distinta: `docker compose ps`, la conexión autenticada, `findOne` y `insertOne`.

Paso 4. Ejecutar y registrar

Registra para cada comprobación:

- comando;

- resultado esperado;
- salida observada;
- interpretación;
- diagnóstico si hubo discrepancia.

No incluyas contraseñas en las capturas o informes. Los nombres ficticios de cuentas y los códigos de error bastan.

Paso 5. Explicar un error esperado

Si la inserción es rechazada con un error de autorización, indica que se trata de la **restricción prevista**. La cuenta consiguió autenticarse y consultar; el servidor negó escribir porque el rol no incluye esa acción.

Paso 6. Separar lo observado de lo inferido

Una prueba de `lectorlab` sobre `secretos` **no demuestra** que todas las colecciones del servidor estén protegidas de la misma forma. Tampoco demuestra que las copias estén cifradas o que los certificados del servidor de TLS sean correctos.

Una conclusión profesional delimita sus afirmaciones a la evidencia disponible.

Paso 7. Entrega final

Tu informe debe contener:

1. Problema y resultado deseado.
2. Datos y entorno de demostración.
3. Cuenta y roles examinados.
4. Operación positiva y resultado.
5. Operación negativa y resultado.
6. Qué has aprendido.
7. Qué otros controles tendrían que probarse en un sistema real.

Solución razonada

«Se probó una instancia local con una colección ficticia. La cuenta de lectura se autenticó contra la base prevista y consiguió consultar el documento preparado. Su intento de inserción fue rechazado por autorización. Los resultados respaldan el funcionamiento de esos roles en este entorno. No acreditan, por sí solos, la configuración de copias, cifrado en reposo o controles de una instalación productiva».

La solución es breve, pero **cada afirmación puede relacionarse con una comprobación concreta**.

Criterio de superación

La práctica está conseguida cuando otra persona puede repetir los pasos, observar resultados comparables y entender por qué algunas acciones deben terminar en error. El éxito no es evitar todos los mensajes de error: es saber **cuáles significan que la política funciona**.